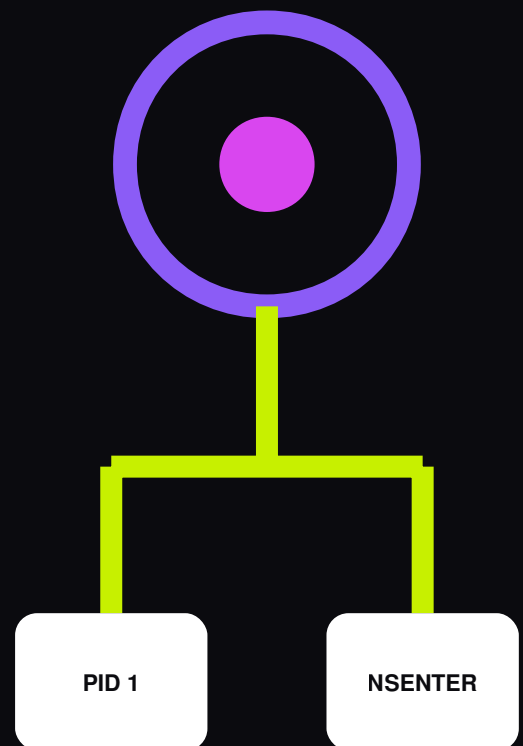


CARBONATO HOST NAMESPACE ENTRY THROUGH NSENTER

Hunts the source-recovered CARBONATO command shape that uses nseniter to join PID 1 host namespaces from a privileged container and launch a Unix shell.

HUNTING QUERY

CONFIDENCE: MEDIUM



EVIDENCE BEFORE ALERTING

REPORT DATE

26 September 2026

STATUS

Untested implementation
sketch

PRIMARY PLATFORM

Microsoft Defender XDR

OPERATIONAL VALUE

9.8 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

9.8

Hunts the source-recovered CARBONATO command shape that uses nsenter to join PID 1 host namespaces from a privileged container and launch a Unix shell.

STATUS

Hunting query

Untested implementation sketch; Confidence Medium.

1primary table

0joins

0secondary rules

2validation gates

Evidence boundary

A result supports investigation of the source-recovered command shape. It does not prove unauthenticated Docker access, successful namespace entry, persistence, mining, C2, CARBONATO identity, or attribution; recovered command history is not equivalent to victim endpoint forensics.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 ThreatDown discovered an unauthenticated Docker registry in August 2026 and recovered CARBONATO configuration, images, command history, and deployment artifacts spanning October 2024 through August 2026.
- 2 CARBONATO creates a privileged alpine container named netns-probe with host PID and network modes plus the host filesystem mounted at /host.
- 3 The Docker exec API then runs the exact command nsenter -t 1 -m -u -n -i sh -c id to enter PID 1 mount, UTS, network, and IPC namespaces and invoke a shell.

Detection hypothesis

If an attacker repeats CARBONATO's privileged-container host takeover, DeviceProcessEvents should show nsenter targeting PID 1, entering four host namespaces, and invoking a shell. Distinction requires workload ownership, initiating-runtime context, image provenance, and approved diagnostic records.

Unconfirmed elements

A result supports investigation of the source-recovered command shape. It does not prove unauthenticated Docker access, successful namespace entry, persistence, mining, C2, CARBONATO identity, or attribution; recovered command history is not equivalent to victim endpoint forensics.

Logic: Campaign-specific behavioral pattern ATT&CK: T1611 / T1059.004



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

Microsoft Defender for Endpoint Linux process-creation telemetry in DeviceProcessEvents, full ProcessCommandLine, and visibility into the relevant container or host process namespace.

OPTIONAL ENRICHMENT

Container/runtime inventory, Docker daemon exposure, parent process and unique identifiers, account context, image provenance, network telemetry, change tickets, and workload ownership.

Fields	Reliability	Use
Timestamp, DeviceId, DeviceName	Documented	Query or triage
FileName, FolderPath, ProcessCommandLine	Documented	Query or triage
ProcessId, ProcessUniqueld	Documented	Query or triage
InitiatingProcessFileName, InitiatingProcessFolderPath	Documented	Query or triage
InitiatingProcessCommandLine, InitiatingProcessUniqueld	Documented	Query or triage
AccountName, SHA1, ReportId	Documented; population varies	Query or triage
Container process visibility	Environment-dependent; validate	Query or triage

Excluded

No Docker request body, inferred namespace-entry success, persistence, mining, C2, actor attribution, or undocumented cross-SIEM mapping is used.



PRIMARY KQL

Direct source-supported conditions with investigable output.

HUNTING

STATUS

Hunting query — Untested implementation sketch

KQL — UNTESTED

```
DeviceProcessEvents
| where FileName =~ "nsenter"
| where ProcessCommandLine contains "-t 1"
| where ProcessCommandLine contains "-m -u -n -i"
| where ProcessCommandLine contains "sh -c"
| project Timestamp, DeviceId, DeviceName, AccountName,
    FileName, FolderPath, ProcessCommandLine,
    ProcessId, ProcessUniqueId,
    InitiatingProcessFileName, InitiatingProcessFolderPath,
    InitiatingProcessCommandLine, InitiatingProcessId,
    InitiatingProcessUniqueId, SHA1, ReportId
| order by Timestamp desc
```

WINDOW
None

THRESHOLD
None

JOIN
None

CORRELATION KEY
Device + process
IDs + time



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain the raw process event, command line, unique process identifiers, account, device, timestamp, and report identifier.

2

Confirm

Identify the workload owner, container runtime, image provenance, SRE or incident-response change record, and host role.

3

Enrich

Container/runtime inventory, Docker daemon exposure, parent process and unique identifiers, account context, image provenance, network telemetry, change tickets, and workload ownership.

4

Scope

Review adjacent Docker API, container, process, file, service, DNS, and network evidence.

Expected benign overlap

Legitimate Kubernetes or container troubleshooting, SRE diagnostics, incident response, sandbox orchestration, and node-maintenance tools can use nsenter against PID 1. Confirm workload owner, initiating runtime, change record, shell payload, image provenance, and recurrence before escalation; do not allowlist by binary name alone.

Response boundary

A result supports investigation of the source-recovered command shape. It does not prove unauthenticated Docker access, successful namespace entry, persistence, mining, C2, CARBONATO identity, or attribution; recovered command history is not equivalent to victim endpoint forensics.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

1. On an isolated Linux test host, run the exact benign command from a controlled privileged container and confirm that DeviceProcessEvents records the process and complete command line.
2. Verify FileName, ProcessCommandLine, InitiatingProcess fields, ProcessUniqueid, and ReportId population in the target Defender tenant.
3. Search an agreed historical period and assign every match to a workload owner, SRE workflow, incident-response action, or unexplained execution.
4. Reject alert deployment if container processes are not covered or approved troubleshooting cannot be separated; retain as a hunt until coverage and baseline are stable.

Decision criteria

Success: The controlled event is captured with intact argument order and process lineage, while historical legitimate matches are attributable and unexplained matches remain reviewable.

Rejection: Container telemetry is absent, command lines are truncated, or approved diagnostics create unresolved overlap that cannot be tuned with ownership and lineage.

Failure: Microsoft Defender for Endpoint is absent, Linux or container process coverage is incomplete, nsenter is renamed or executed through a different path, or the attacker changes the namespace-entry method.

Platform	Decision	Missing evidence
Defender XDR	Hunting query	Linux container coverage and baseline
Splunk	No reliable implementation	Index, sourcetype, parser, sample
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Hunting query

Hunts the source-recovered CARBONATO command shape that uses nsenter to join PID 1 host namespaces from a privileged container and launch a Unix shell.

A result supports investigation of the source-recovered command shape. It does not prove unauthenticated Docker access, successful namespace entry, persistence, mining, C2, CARBONATO identity, or attribution; recovered command history is not equivalent to victim endpoint forensics.

MITRE ATT&CK

T1611 / T1059.004

References

- 1. ThreatDown — CARBONATO: a botnet built around an AI agent — published 22 Sep 2026; registry discovered Aug 2026; archive spans Oct 2024–Aug 2026
- 2. Microsoft Learn — DeviceProcessEvents advanced hunting schema — updated 07 Aug 2026; accessed 26 Sep 2026
- 3. MITRE ATT&CK — T1611 Escape to Host; T1059.004 Unix Shell

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.